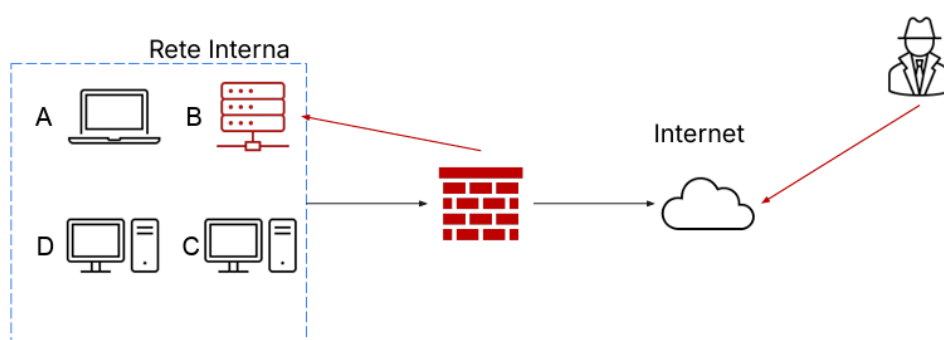


Report 05/05/26

Alunno: Pancrazio Giuzio

Traccia:

Con riferimento alla figura nella prossima slide, il sistema B (un database con diversi dischi per lo storage) è stato compromesso interamente da un attaccante che è riuscito a bucare la rete e accedere al sistema tramite Internet. L'attacco è attualmente in corso e siete parte del team di CSIRT. Rispondere ai seguenti quesiti. • Mostrate le tecniche di: I Isolamento II Rimozione del sistema B infetto • Spiegate la differenza tra Purge e Destroy per l'eliminazione delle informazioni sensibili prima di procedere allo smaltimento dei dischi compromessi. Indicare anche Clear



Facoltativo: In una grande azienda, due utenti segnalano problemi sui loro computer e chiedono assistenza al reparto CSIRT/SOC (che siamo noi) Analizzare i seguenti link e fare un piccolo report di quello che si scopre relativo alla segnalazione dell'eventuale attacco:
<https://tinyurl.com/linklosco1> e <https://tinyurl.com/linklosco2>

Svolgimento:

Come possiamo notare dall'immagine fornitaci sopra, in questo caso l'attaccante ha avuto un accesso ad un nostro dispositivo in rete interna tramite internet, questo una volta notato dovrebbe subito portare ad un isolamento del dispositivo per poter evitare che l'attaccante possa muoversi all'interno della rete, quindi si procede con l'isolamento.

L'isolamento è una tecnica che permette di isolare un dispositivo compromesso in un'altra area della rete accessibile solo da internet e non dalla rete interna, questo però comporta comunque lo svantaggio di avere l'attaccante che comunque potrà ancora accedervi. (potrebbe essere un buon sistema temporaneo mentre si pulisce e/o si recupera il dispositivo compromesso integrandolo con nuove misure di sicurezza)

La Rimozione , invece è una tecnica che isola completamente il dispositivo infetto , questo non avrà più accesso ad internet tantomeno sarà presente nella rete interna . cosi' viene di fatto anche esclusa l'eventualità che l'attaccante possa rimanere dentro un dispositivo compromesso.

Il "Purge" è una tecnica che viene usata per ripristinare dispositivi , in maniera logica ES: un attaccante ha infettato vari dischi , oppure noi vogliamo liberarcene in quanto obsoleti o non funzionanti , questa tecnica ci permette di scrivere piu' volte sui dischi e quindi logicamente portare ad uno stato di non leggibilità dei vecchi dati che sono stati utilizzati , questo ciclo ovviamente per avere un buon effetto deve essere fatto con dei tool appositi che scrivono piu' volte sezioni di disco invalidando cosi' la tecnica del "forensic recovery " che potrebbe essere effettuata.

il "Destroy" invece è una tecnica che mira a distruggere fisicamente varie parti del dispositivo per rendere i dati inaccessibili , questo molte volte viene fatto quando il dispositivo è completamente compromesso e o a fine vita . si tratta di praticamente danneggiarlo al punto tale di non rendere piu' ricostruibile o leggibile il contenuto all'interno , es: bucadolo piu' volte con un trapano , o lanciando un impulso elettromagnetico che possa comprometterne la i dati ed il funzionamento.

il "Clear" è una tecnica simile al purge che va a riscrivere dischi in maniera logica randomizzando gli uno e gli zero nei vari settori , questo pero' non è immune ad una ricostruzione dei dati anche dopo questo processo. si puo' utilizzare questa tecnica per riutilizzare dischi anche in caso di lieve compromissione.

Facoltativo

<https://tinyurl.com/linklosco1>

da questo link possiamo notare facilmente che l'utente ha avuto accesso ad una pagina di github dedicata a condivisione di frammenti di codice , questo molto spesso viene visto come traffico legittimo da firewall , purtroppo il codice che v`a a scaricare ed eseguire in formato ps1 ovvero power shell è un codice che cambia la configurazione dei dns facendo cosi' in modo che ,ogni volta che l'utente decida di navigare le richieste dns passino per le mani dell'attaccante avendo il pieno controllo di poter utilizzare server malevoli per rubare password o far scaricare altri file che compromettano ancora di piu' il sistema . in questo caso la migliore cosa da fare è ripulire il computer dall'iniezione di questo codice , cercare di vedere se altre risorse stesse del computer possano essere state compromesse , mettere un blocco sul firewall agli indirizzi ip destinatari del dns.

<https://tinyurl.com/linklosco2>

in questa analisi vediamo che tutto inizia con il download di un file da un link di google drive che serve a scavalcare i controlli di sicurezza sfruttando l'affidabilità del dominio di google . Una volta avviato questo file non agisce subito ma lancia un comando powershell offuscato ovvero scritto in modo illeggibile per non farsi scoprire dagli antivirus , questo comando scarica un codice malevolo direttamente nella memoria ram del computer senza salvare file sul disco fisso rendendo l'infezione quasi invisibile .Una volta dentro il malware analizza i database dei browser per estrarre password salvate e cookie di sessione e infine apre una connessione diretta verso un server esterno gestito dall'attaccante per spedirgli tutti i dati rubati completando così il furto delle informazioni personali in modo silenzioso e costante. in questo caso la pulizia va fatta a livello piu' profondo in quanto l'esfiltrazione di dati probabilmente è già avvenuta , dovendo quindi sanificare i parametri aziendali dell'utente , verificarne lo stato di compromissione nei server , analizzare i log per capire se c'è stato un accesso non autorizzato a livello di rete interna .